



Lab 13 — Design the Agentic Security Control Stack

Topic 04: Security Controls for Agentic AI, Risk Assessment and Implementation Roadmap

Objective: Implement layered security controls for an agentic AI system: identity, guardrails, permission ladders, sandboxing and human approval gates.

Goal: You will redesign NovaAssist with a real defence-in-depth stack. Working from the OWASP Agentic Security Top 10, you will specify each control layer, decide which tool calls need approval, and write the permission policy that governs the agent before it acts.

What you'll build: A layered agentic control specification: agent identity and scopes, guardrail rules, a deny/ask/allow permission policy for 12 tools, sandbox boundaries and human approval gates.

Tools and data: NovaAssist tool catalogue (agent-tool-catalogue.csv), OWASP ASI Top 10 reference, control stack template

Data files in this lab

- data/agent-tool-catalogue.csv
- data/control-stack-template.md
- data/owasp-asi-top10.md

Step-by-step

1. Open agent-tool-catalogue.csv in labs/lab-13-agentic-controls/data/. Twelve tools are listed with their function, the data they reach and whether their effect is reversible.
2. Classify every tool by consequence: read-only, write-reversible, write-irreversible or external-communication. This classification, not the tool name, determines the control it needs.
3. Layer 1 — identity. Specify NovaAssist's own agent identity, separate from any user account, with the minimum scopes it needs. State how each action stays attributable to the accountable owner.
4. Layer 2 — guardrails. Define the input checks (PII detection, jailbreak and injection patterns) and the output checks (PII redaction, unsafe-content filtering, grounding check). Record explicitly what guardrails cannot do.
5. Layer 3 — permission ladder. For each of the twelve tools assign deny, ask or allow. Every irreversible or external-communication tool must be ask or deny. Justify each allow in one sentence.

deny → ask → allow

6. Write three concrete deny rules that a policy engine could enforce, for example: deny any outbound send whose body contains an account number pattern; deny any tool call in the same turn as a detected injection; deny writes outside the case workspace.
7. Layer 4 — sandboxing. Define the blast radius: the filesystem the agent may touch, the network destinations it may reach, and the credentials it never holds directly.
8. Layer 5 — human approval. Specify which actions require a human gate, what the approver sees, and the service level for a response. Then address approval fatigue: state the volume above which your gate stops being a control.
9. Map your stack to the OWASP Agentic Security Top 10 and confirm coverage for goal hijack, tool misuse, identity and authorisation, memory poisoning, RAG poisoning and excessive agency. Record any risk your stack does not cover.
10. State the residual risk honestly: name the two attack paths that survive all five layers and the compensating detection you would add for each.

Test it

Every irreversible and external-communication tool is set to ask or deny. Your three deny rules are specific enough to be implemented, and you can name at least two attack paths your stack does not stop.

Training use only. The organisation, data and individuals in this lab are fictional. Security techniques taught here must only be applied to systems you own or have written authorisation to test.